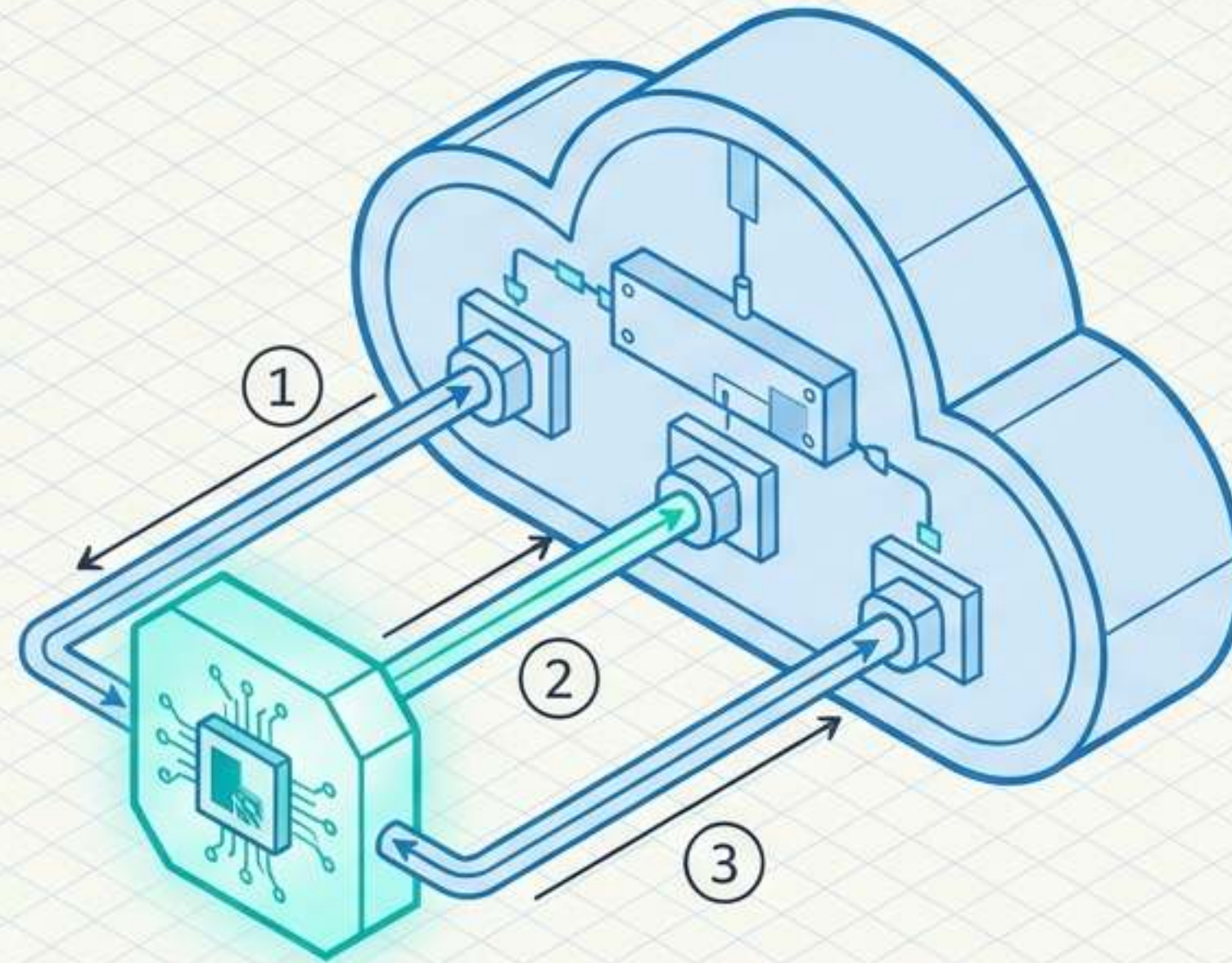


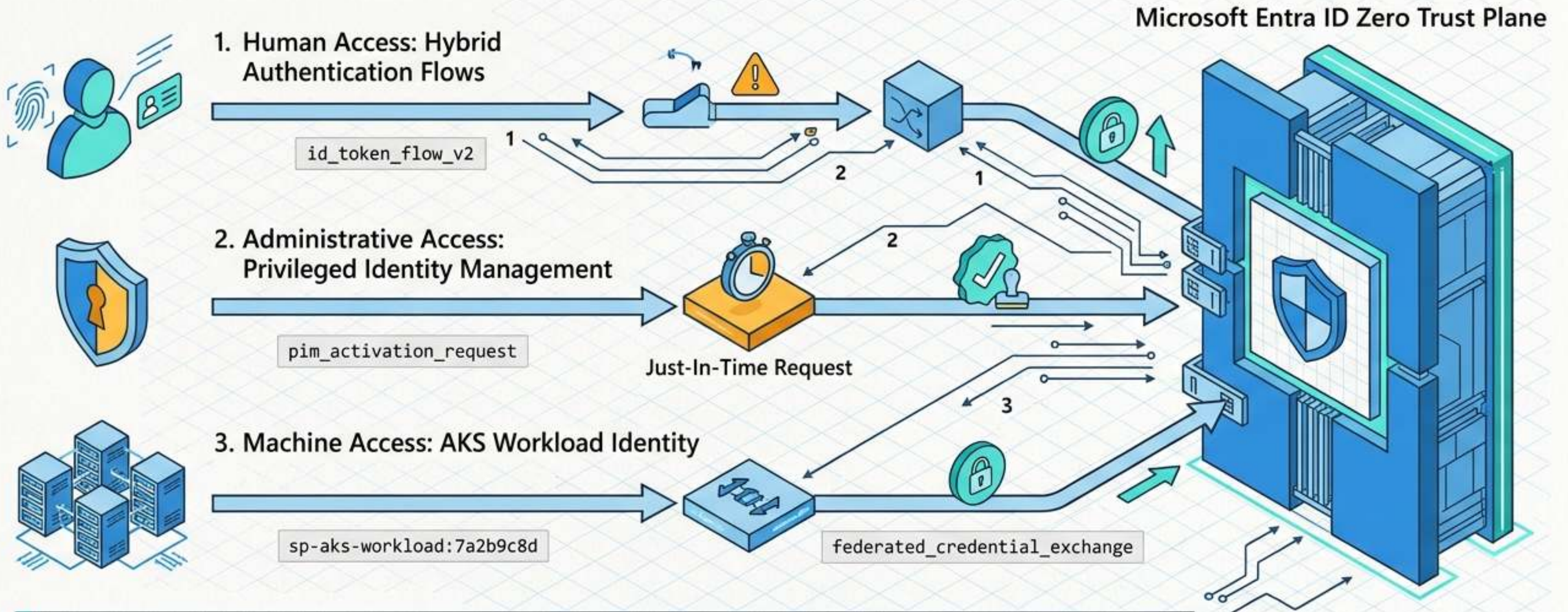


AZ-500 Advanced Identity Architecture

Request Flows for Hybrid Auth, PIM, and AKS Workload Identities

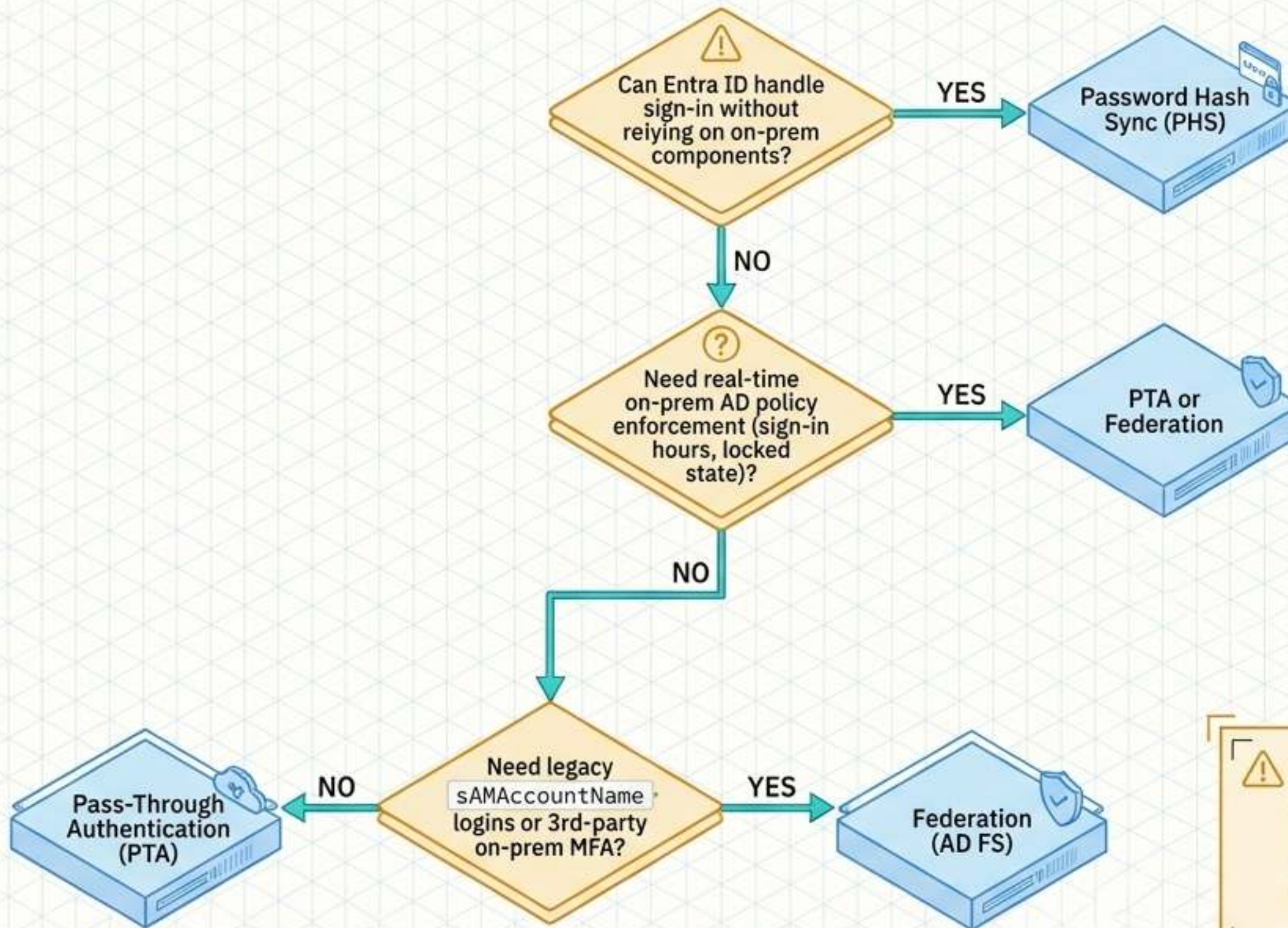
A visual reference guide for modern Zero Trust engineering.

The Three Dimensions of Cloud Access



Microsoft Entra ID acts as the singular trust broker. This guide traces the mechanical request flows across all three dimensions of modern cloud access.

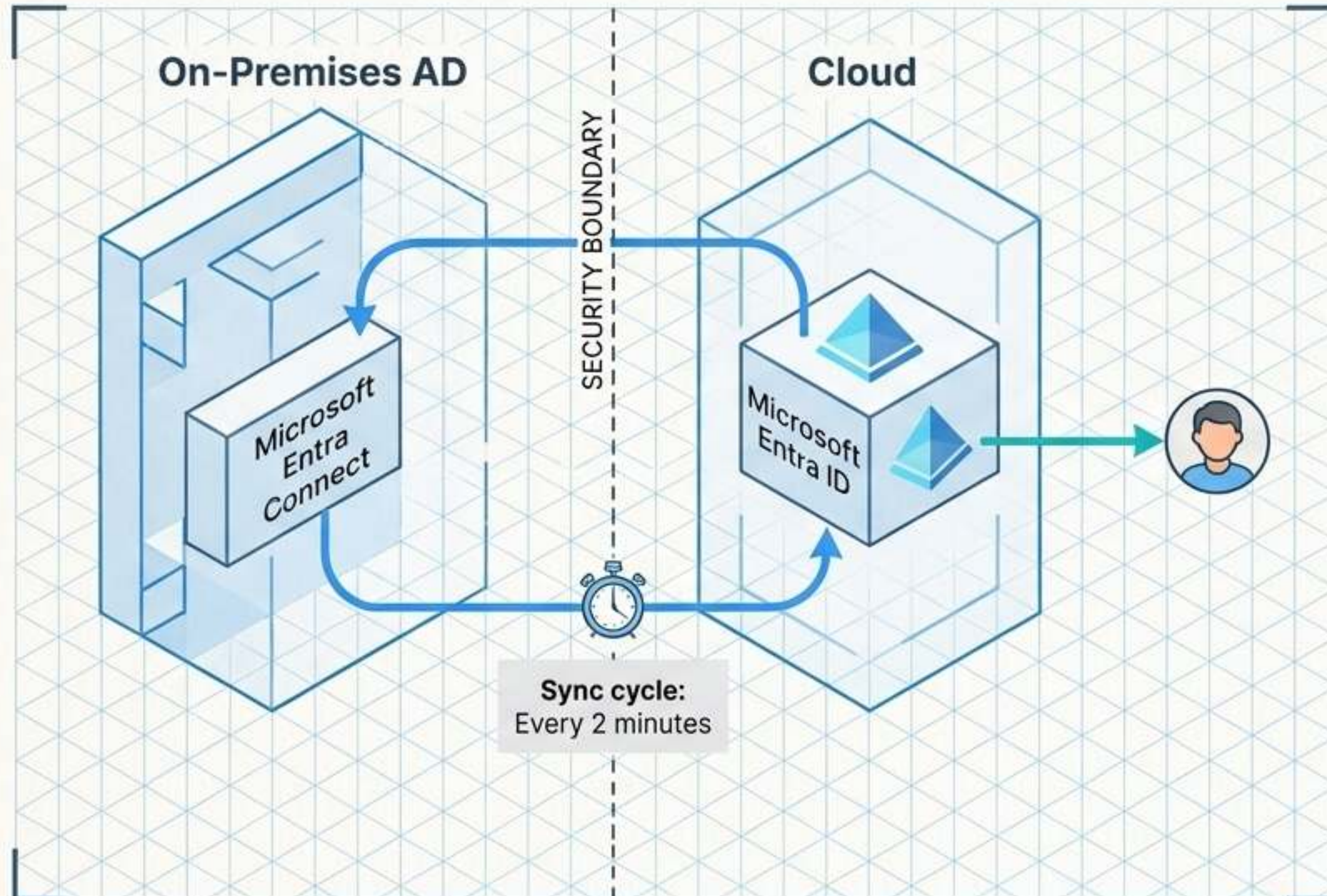
Hybrid Authentication Decision Tree



ARCHITECTURE RULE:

Always enable Password Hash Sync (PHS) as a high-availability backup, regardless of primary method. It provides disaster recovery if on-prem servers fail and unlocks Entra ID Leaked Credential Detection.

Password Hash Sync (PHS) Architecture



Key Mechanics:

Core Mechanic:

Cloud-native authentication.
Hashes sync securely from on-prem.

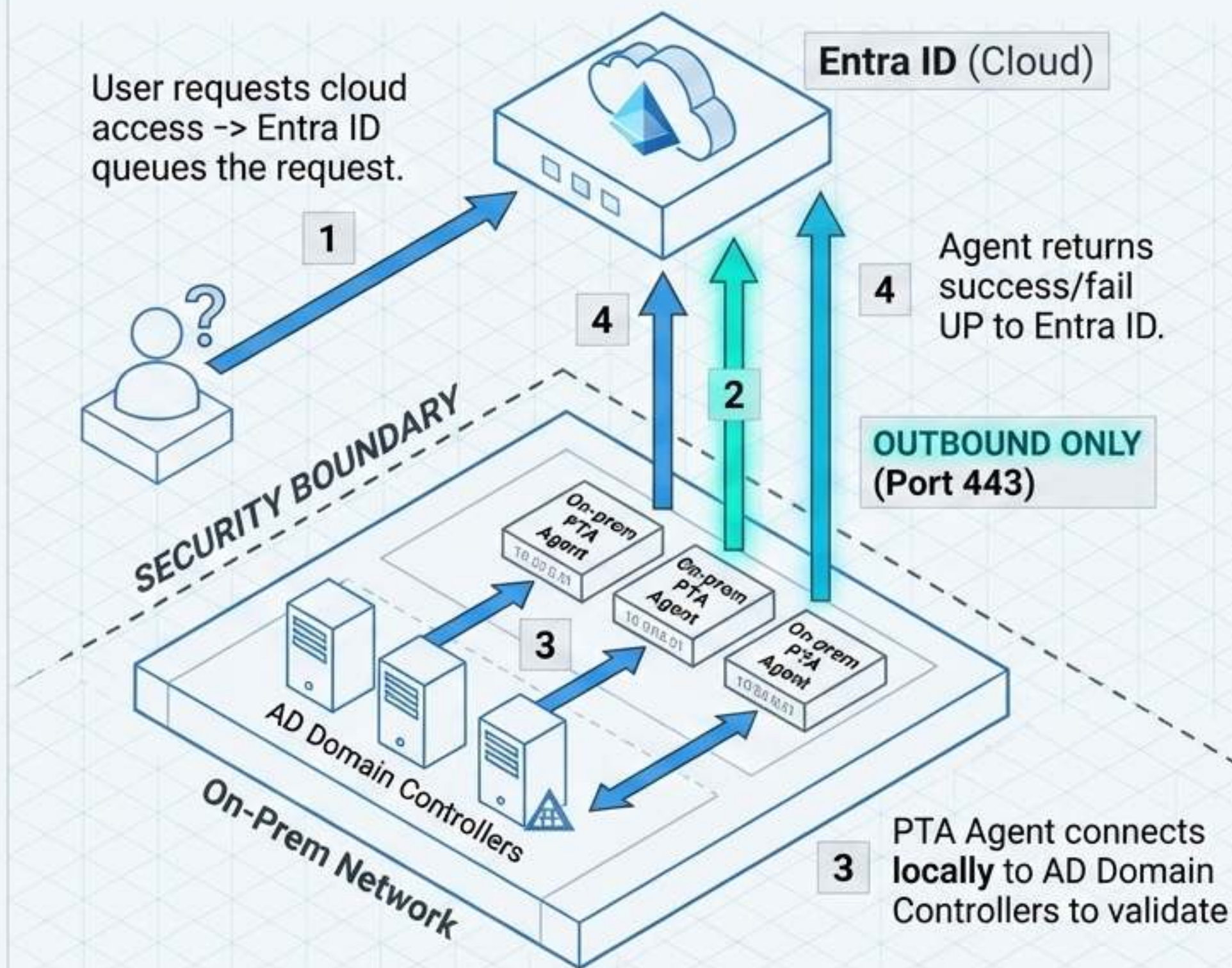
Advantage:

Highest availability. Survives total on-prem network outages.



EXAM NUANCE: PHS does not instantly enforce on-prem account disablement. A disabled on-prem AD account can take up to 30 minutes to sync and block cloud access.

Pass-Through Authentication (PTA) Request Flow



Key Mechanics:

Security:

No DMZ required.

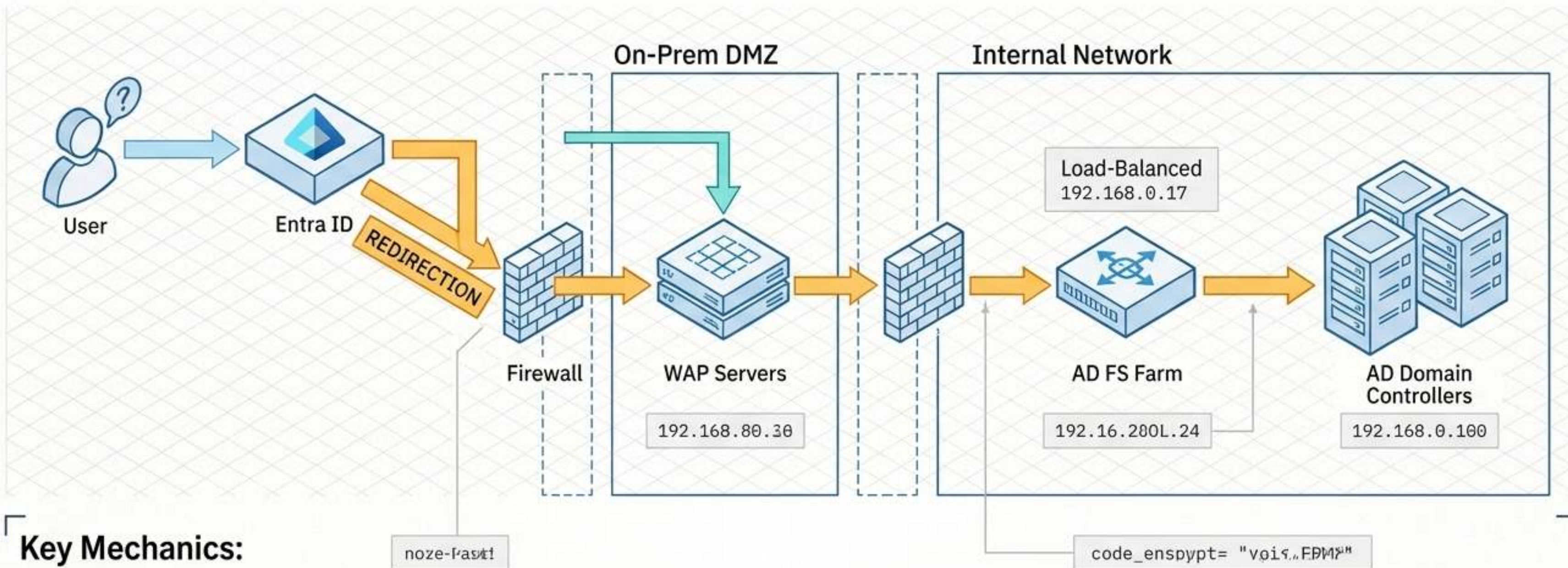
Traffic is strictly outbound polling.

Deploy 3 agents for High Availability.

Advantage:

Enforces on-prem policies (sign-in hours, expired passwords, lockouts) in real-time at the exact moment of sign-in.

Federated Authentication (AD FS)



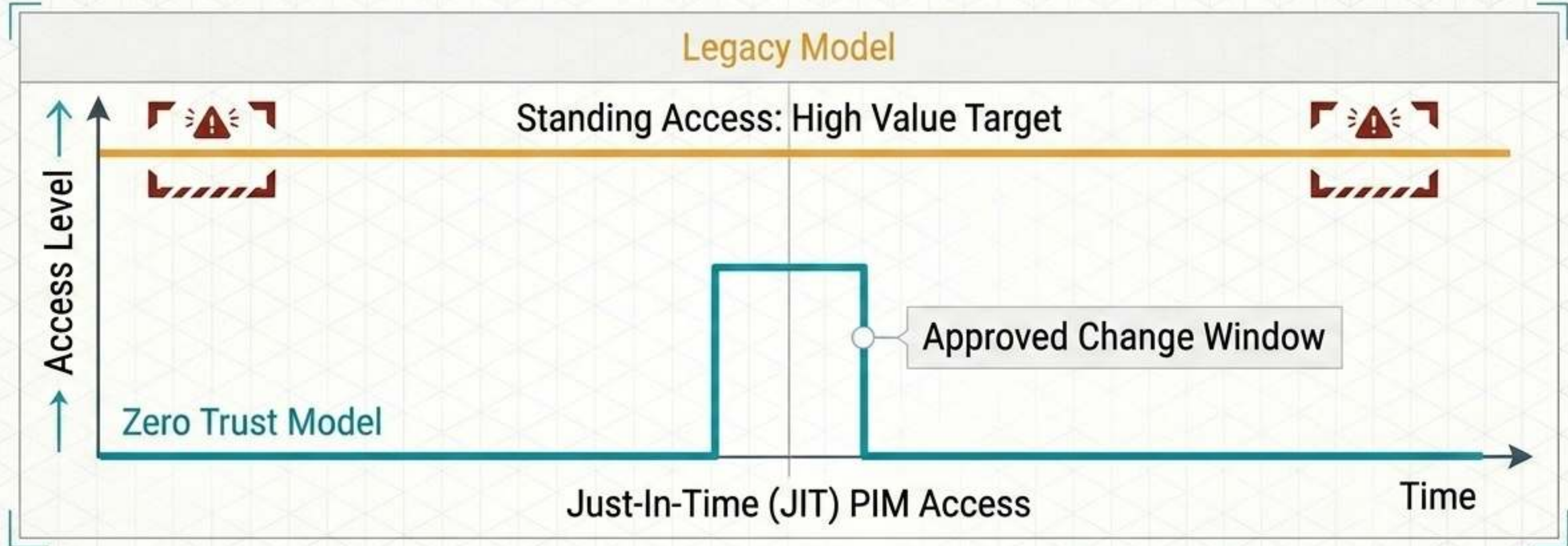
Hybrid Identity Diagnostic Matrix

Feature	PHS	PTA	Federation (AD FS)
Where Auth Happens	Cloud	Cloud via On-Prem Agent	On-Prem
Infrastructure Needed	None	3 Lightweight Agents	AD FS Farm + WAP + DMZ
Real-Time On-Prem State Enforcement	 X X (Up to 30 min delay)		
Leaked Credential Detection		 X (Unless PHS enabled)	 X
High Availability	Cloud-Native HA	Requires Agent Redundancy	Requires Full On-Prem DR

SYNTHESIS:

PHS is the only method unlocking Leaked Credential Reports. PTA is the simplest zero-infrastructure way to get real-time AD enforcement.

The PIM Philosophy: Zero Standing Access



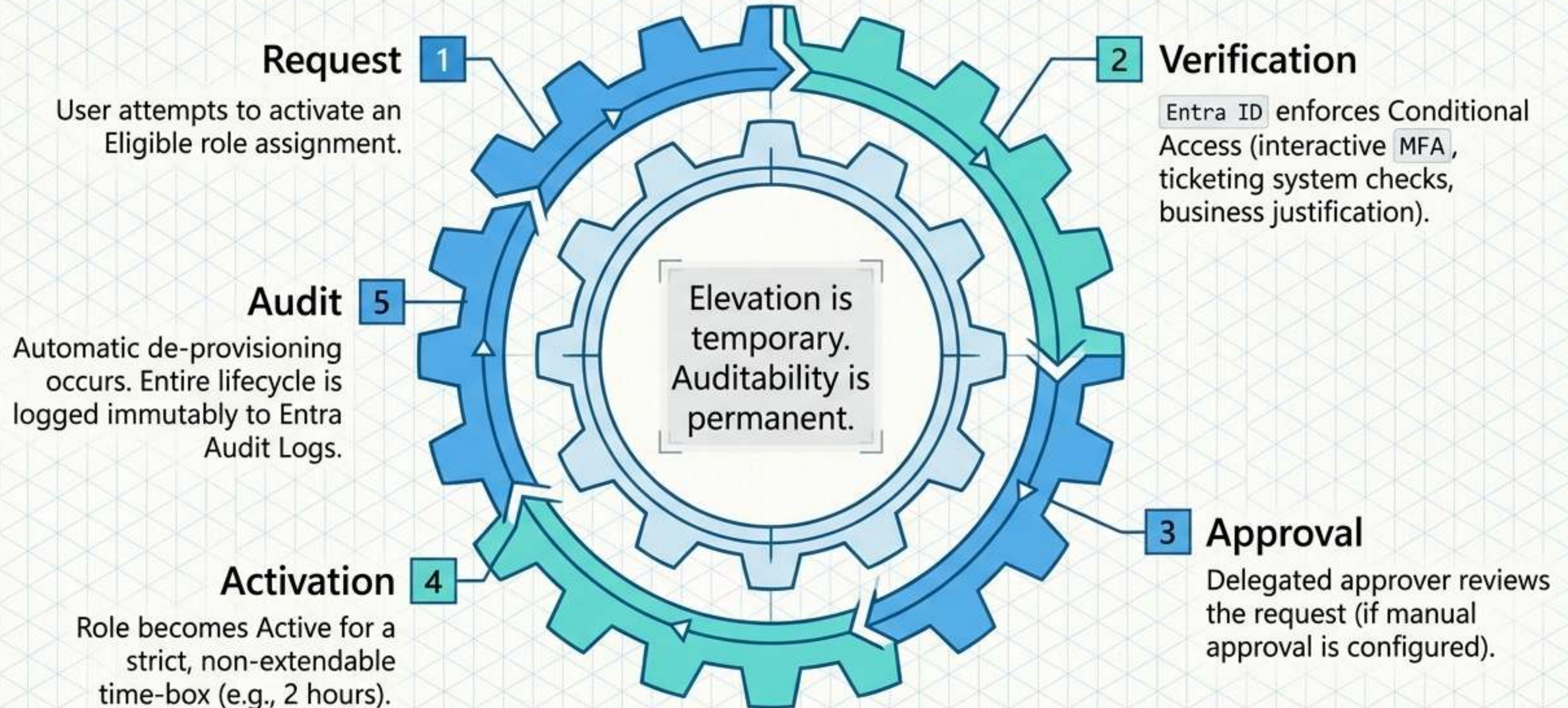
THE RISK:

Permanent privileged roles are highly vulnerable to credential theft and lateral movement.

THE SOLUTION:

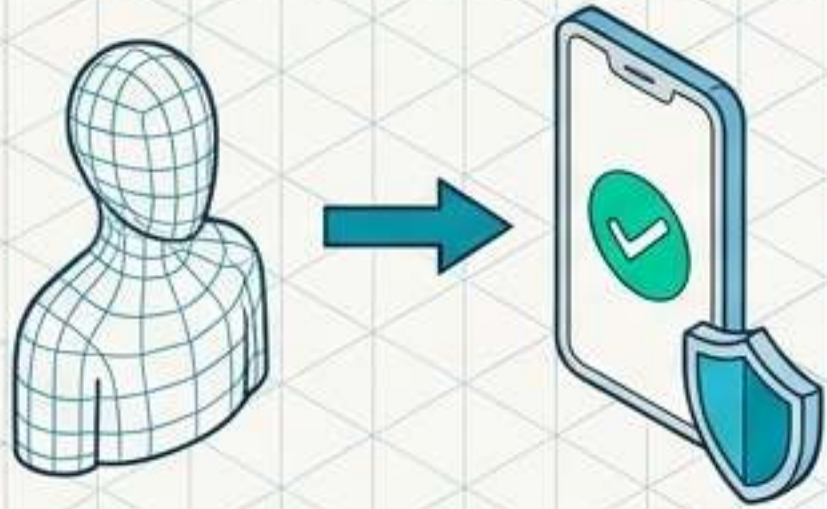
Privileged Identity Management (PIM) replaces standing access with monitored, time-bound elevation.

The PIM Lifecycle & Approval Flow



PIM Nuance: Humans vs. AI/Machine Agents

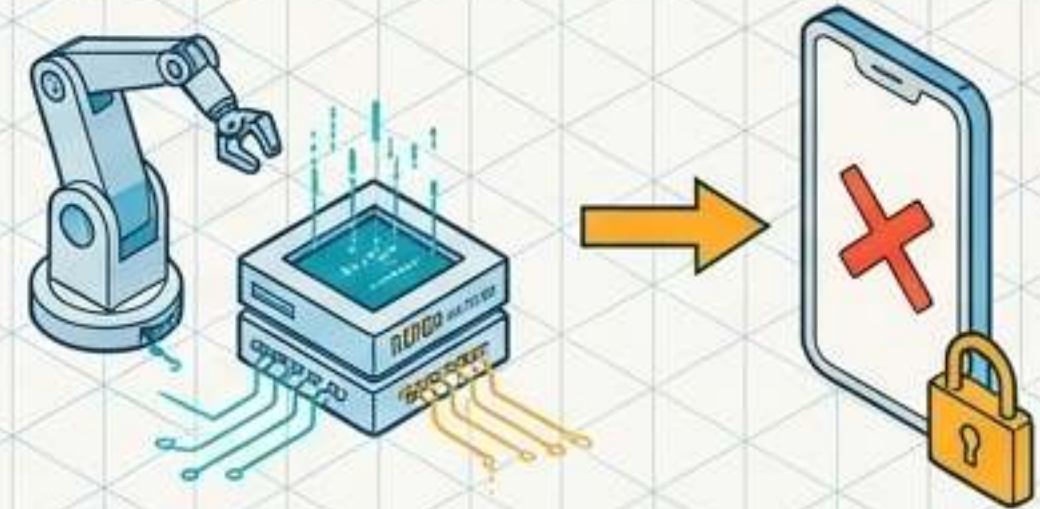
Human Administrators



Eligible Assignments Supported

Humans can interactively satisfy MFA prompts and supply business justifications

AI Agents & Service Principals

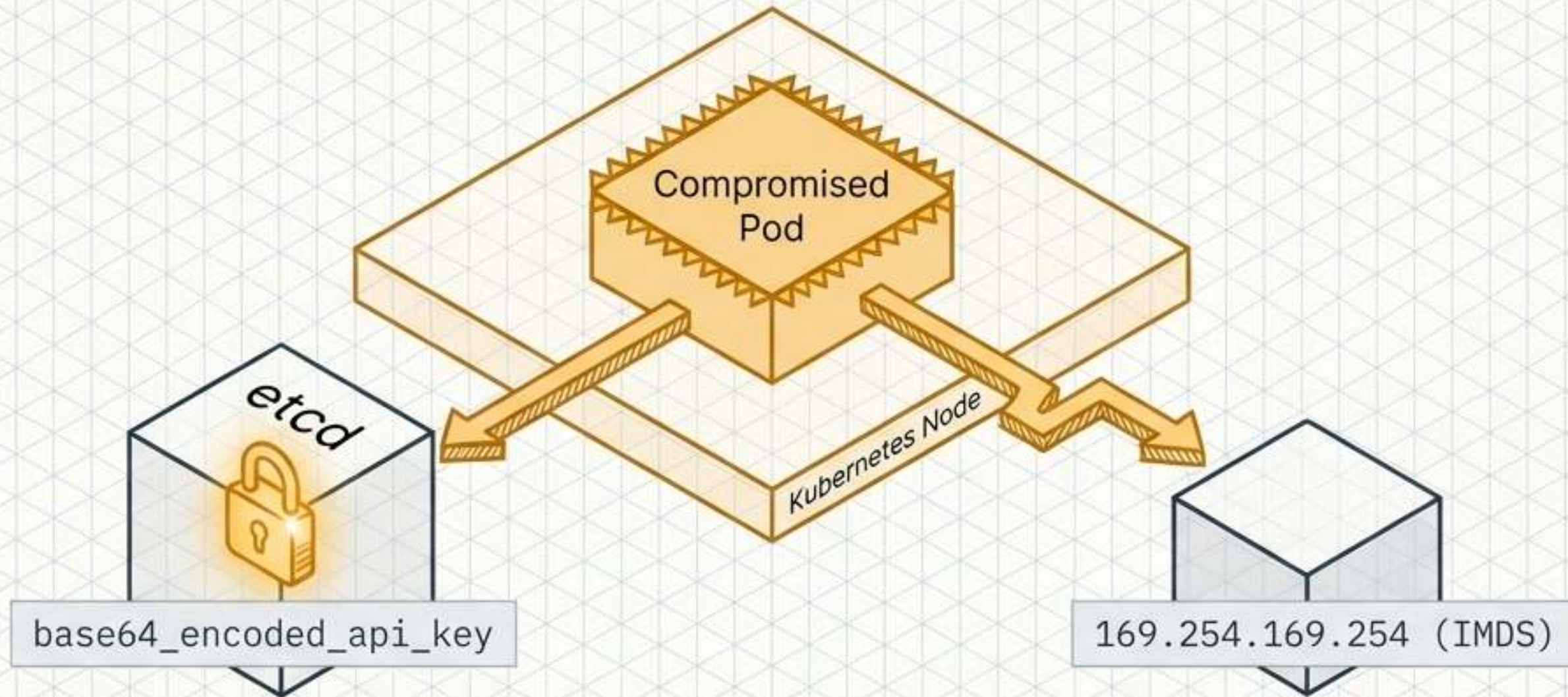


Active Time-Boxed Assignments Required

Machines cannot interactively pass MFA. Service Principals cannot use Eligible assignments

THE FIX: Administrators must provision Service Principals with **Active** assignments constrained by strict **Start** and **End dates** to limit exposure

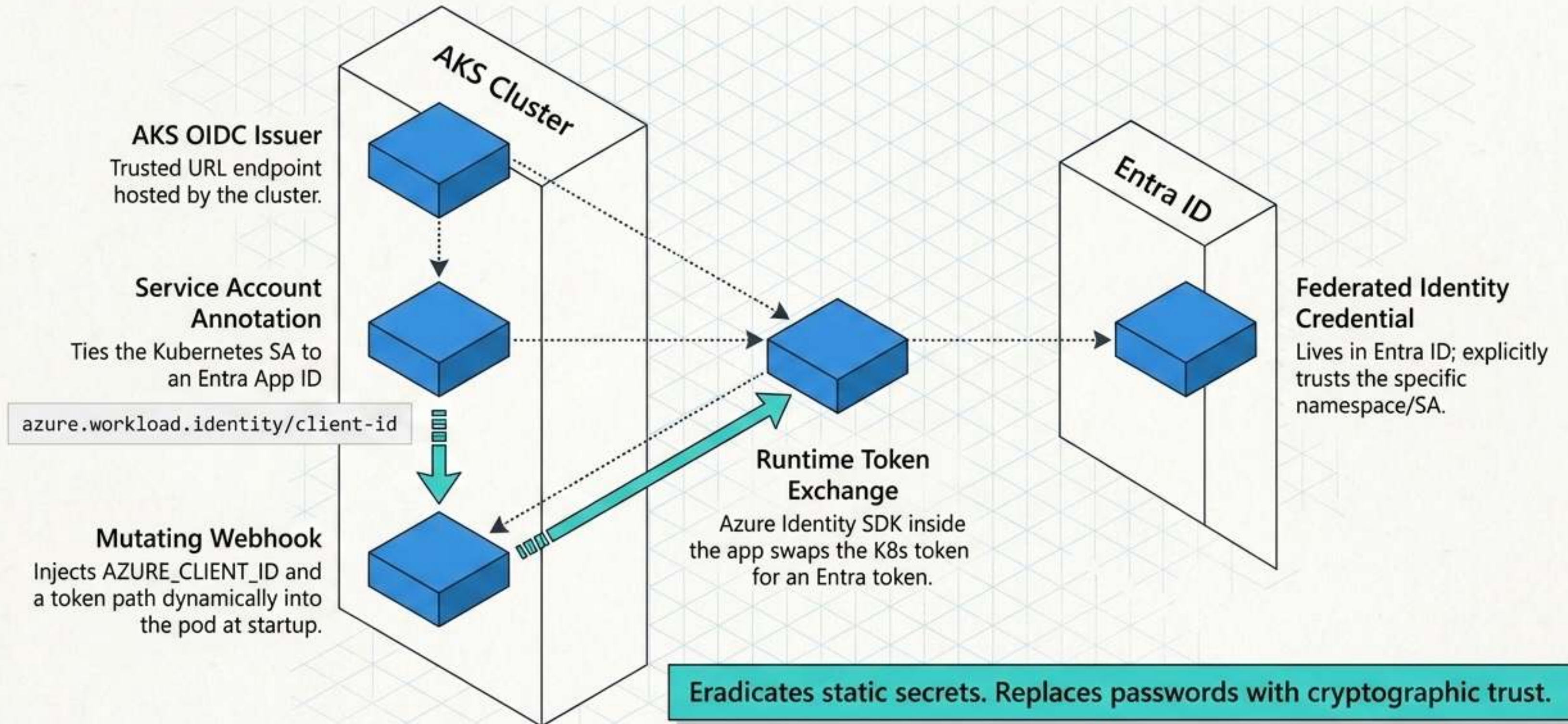
The AKS Secret Problem



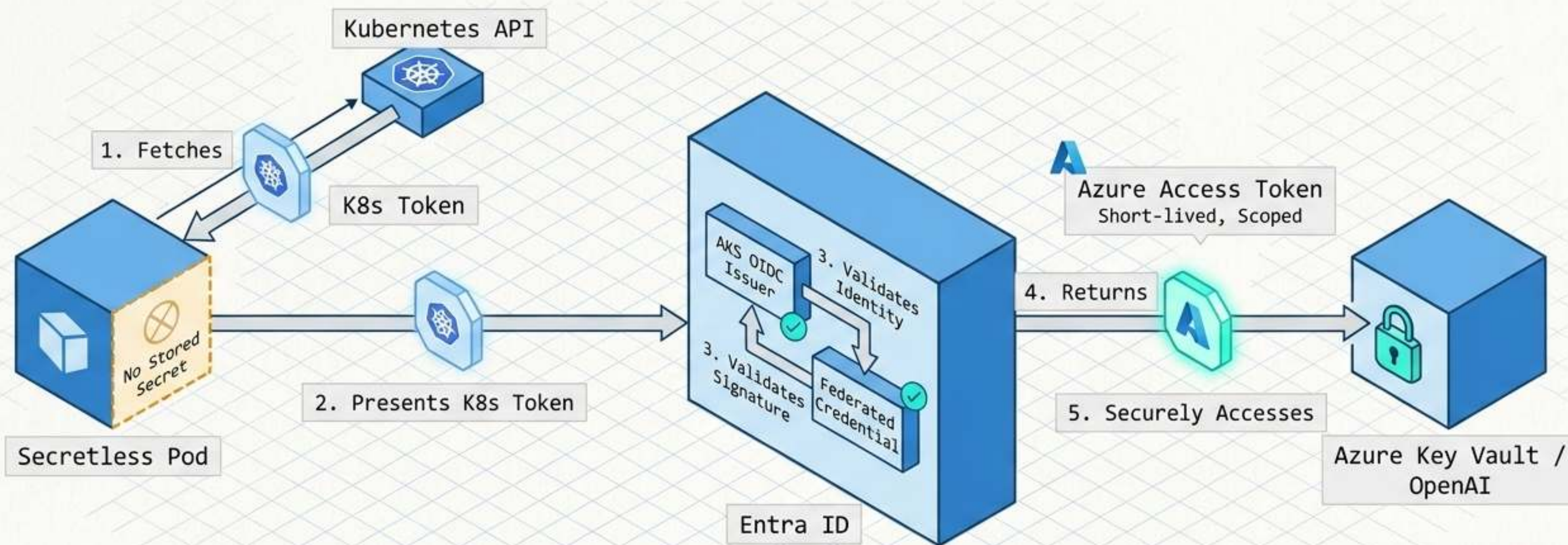
Traditional Kubernetes Secrets are merely base64 encoded. If stolen, they grant infinite standing access.

IMDS Threat: If pod egress to 169.254.169.254 isn't blocked, any pod can escalate privileges by impersonating the host Azure VM.

Workload ID Architecture Components

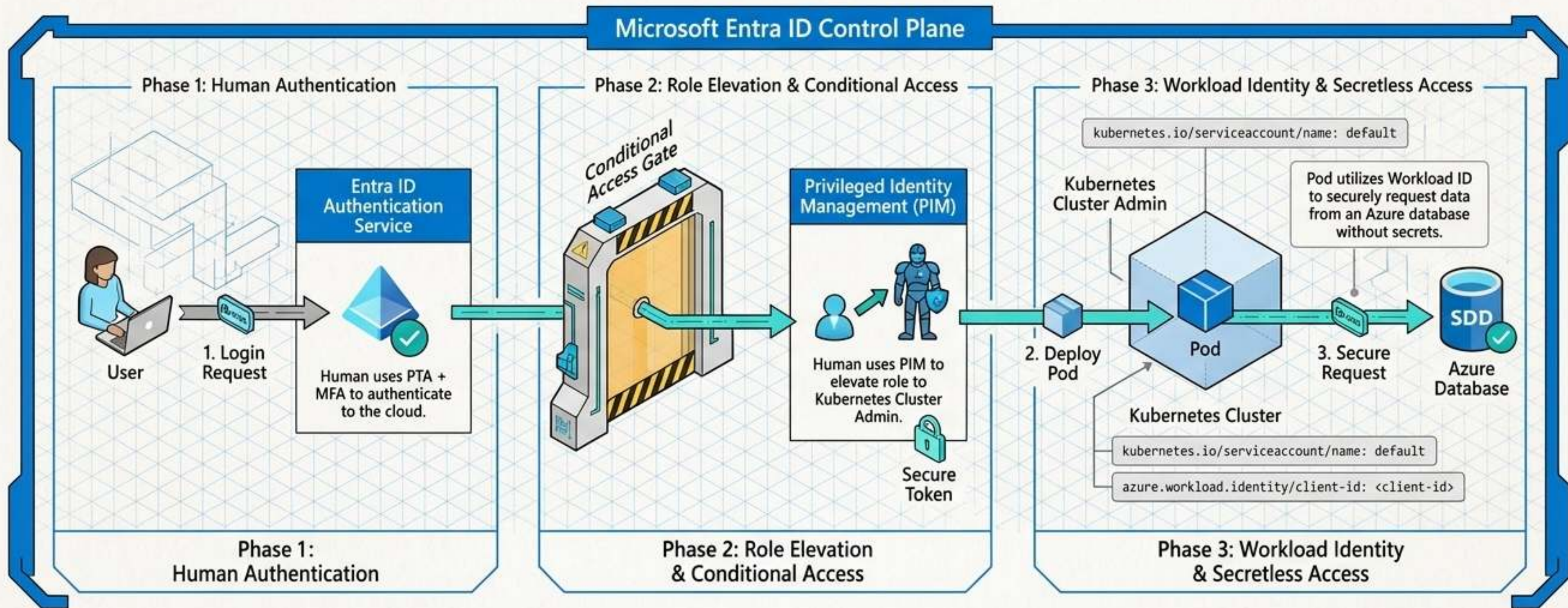


Workload ID Token Exchange Sequence



- No passwords.
- No stored keys.
- No etcd exposure.

Synthesis: The Unified Zero Trust Plane



Identity is the new perimeter. Whether the entity is a human logging in, an administrator elevating access, or a container fetching data, Entra ID enforces a single, unbroken chain of trust.

AZ-500 Architecture Cheat Sheet

Hybrid Auth

- ✓ **PHS** = Resilient backup & Leaked Credential detection.
- ✓ **PTA** = Real-time on-prem policy enforcement; outbound port 443.
- ⚠ **AD FS** = Legacy/complex requirements; highest overhead.

PIM Lifecycle

- 👤 **Humans** = Eligible assignments (JIT, interactive MFA).
- 🤖 **Service Principals** = Time-boxed Active assignments (No interactive MFA).

AKS Workload ID

- ⚠ Do not store API keys in Kubernetes Secrets.
- ✓ Requires: OIDC Issuer + Mutating Webhook + Federated Credential.

AKS Network Security

- ⚠ Block pod egress to IMDS using NetworkPolicy to prevent token theft.

169.254.169.254

Architecture dictates security. End of Reference Document.